

Self-Assessment Questionnaire (SAQ)

Document ID	Version	Owner	Effective Date	Framework	Classification
[DOC-ID]	1.0	[PCI Compliance Owner]	[Effective Date]	PCI DSS v4.0.1	Confidential

Purpose

This Self-Assessment Questionnaire Attestation documents management's formal representation that [Organisation Name] has completed the applicable PCI DSS self-assessment process for the cardholder data environment and in-scope payment channels.

The purpose of this Attestation is to confirm that:

- The correct Self-Assessment Questionnaire type has been selected based on how [Organisation Name] stores, processes, transmits, or could impact the security of cardholder data.
- The self-assessment was completed using accurate, current, and complete information.
- The responses in the Self-Assessment Questionnaire are supported by evidence.
- Any identified gaps have been documented, risk-assessed, and assigned remediation ownership.
- Management accepts responsibility for the accuracy of the submission and for maintaining PCI DSS compliance after the assessment date.

This document is intended for use by internal stakeholders, acquiring banks, payment brands, service providers, auditors, assessors, and other authorised parties requiring evidence of PCI DSS self-assessment completion.

Scope

This Attestation applies to the PCI DSS self-assessment performed by [Organisation Name] for the assessment period ending [Assessment End Date].

The assessed environment includes all people, processes, technologies, locations, payment channels, third parties, and network segments that store, process, transmit, or could affect the security of cardholder data.

Applicable SAQ Type

Item	Attested Response
Applicable SAQ Type	[SAQ A / SAQ A-EP / SAQ B / SAQ B-IP / SAQ C / SAQ C-VT / SAQ P2PE / SAQ D Merchant / SAQ D Service Provider]
Reason for SAQ Selection	[Brief description of payment channels and processing model supporting SAQ type selection]
Merchant or Service Provider Role	[Merchant / Service Provider / Both]
Merchant Level or Service Provider Category	[Applicable level/category, if known]
Acquiring Bank or Payment Brand Requesting Attestation	[Name]
Assessment Period Covered	[Start Date] to [End Date]
Assessment Completion Date	[Completion Date]

In-Scope Payment Channels

Payment Channel	Included in Assessment	Description	Primary Technology or Provider
E-commerce	[Yes/No]	[Hosted payment page, redirect, iframe, direct post, API, or other model]	[Platform / Provider]
Mail order / telephone order	[Yes/No]	[Call centre, virtual terminal, paper forms, or other model]	[Platform / Provider]
Card-present retail	[Yes/No]	[Point-of-sale terminals, attended/unattended devices, or mobile POS]	[Platform / Provider]
Recurring payments	[Yes/No]	[Tokenised billing, customer vaulting, subscription platform, or other model]	[Platform / Provider]
Back-office payment handling	[Yes/No]	[Refunds, chargebacks, reconciliation, support processes]	[Platform / Provider]

In-Scope Locations

Location	Function	In Scope	Notes
[Head Office]	[Administration / finance / support]	[Yes/No]	[Notes]
[Retail Site / Branch / Facility]	[Payment acceptance / operations]	[Yes/No]	[Notes]
[Data Centre / Cloud Region]	[Hosting / processing / storage]	[Yes/No]	[Notes]
[Remote Workforce]	[Support / administration / payment handling]	[Yes/No]	[Notes]

In-Scope Systems and Services

The following systems, applications, networks, and services were considered for the self-assessment:

System or Service	Function	In-Scope Rationale	Owner
[Payment Application / Platform]	[Payment capture, processing, tokenisation, reporting]	[Stores/processes/transmits cardholder data or affects security]	[System Owner]
[E-commerce Website]	[Customer payment journey]	[Can impact payment page security or redirect integrity]	[System Owner]
[Virtual Terminal]	[Manual payment entry]	[Used by staff to process card payments]	[Business Owner]
[POS Terminals]	[Card-present payment acceptance]	[Used to accept payment cards]	[Operations Owner]
[Network Segment]	[Connectivity/security boundary]	[Supports in-scope systems or administrative access]	[Infrastructure Owner]
[Cloud Hosting Service]	[Hosting/payment support services]	[Hosts or supports in-scope components]	[Cloud Owner]
[Logging/SIEM Platform]	[Security monitoring]	[Collects logs from in-scope systems]	[Security Owner]

Out-of-Scope Items

Systems, services, or locations are considered out of scope only where [Organisation Name] has confirmed that they do not store, process, transmit, or affect the security of cardholder data and are appropriately separated from the in-scope environment.

Item	Reason Excluded	Validation Performed
[System / Location / Process]	[No cardholder data interaction and no security impact on in-scope environment]	[Network review / data-flow validation / process walkthrough / provider confirmation]
[System / Location / Process]	[Handled entirely by validated third party with no organisational access to cardholder data]	[Contract review / responsibility matrix / attestation review]

Third-Party Service Providers

The following third-party service providers were considered because they store, process, transmit, or could affect the security of cardholder data on behalf of [Organisation Name]:

Provider	Service Provided	PCI Responsibility Impact	Evidence Reviewed
[Payment Processor]	[Authorisation, settlement, tokenisation]	[Processes cardholder data]	[Attestation of compliance / responsibility matrix / contract]
[Payment Gateway]	[Hosted payment page, API gateway, transaction routing]	[Processes or transmits payment data]	[Attestation of compliance / service description]
[Cloud Provider]	[Infrastructure, platform, hosting]	[Hosts or supports in-scope environment]	[Compliance report / shared responsibility documentation]
[Managed Service Provider]	[Administration, monitoring, support]	[May affect security of in-scope systems]	[Contract, access records, security commitments]

Attestation Statement

Management of [Organisation Name] attests that, to the best of its knowledge and based on the evidence reviewed, the applicable PCI DSS Self-Assessment Questionnaire has been completed for the assessed environment described in this document.

By signing this Attestation, [Organisation Name] confirms that:

- The SAQ type identified in this document is appropriate for the organisation's payment acceptance channels, processing methods, technical architecture, and use of third-party service providers.
- The scope of the assessment was defined using current payment flows, network diagrams, system inventories, third-party service listings, access paths, and business process information.
- All known locations, applications, systems, networks, people, and service providers that store, process, transmit, or could affect the security of cardholder data were considered.
- Cardholder data flows were reviewed and are understood by the business, technology, and security owners responsible for the assessed environment.
- The responses recorded in the completed SAQ are accurate as of [Assessment Completion Date].
- Evidence supporting the SAQ responses was reviewed and retained in accordance with this document.
- Where a requirement was marked as in place, [Organisation Name] has evidence showing that the relevant security practice, control, configuration, process, or monitoring activity was operating at the time of assessment.
- Where a requirement was marked as not applicable, the rationale was documented and is supported by the assessed environment design or business process.
- Where a requirement was not fully in place, the gap was documented, assigned to an accountable owner, and included in a remediation plan.
- [Organisation Name] has not intentionally omitted any known cardholder data environment component, payment process, third-party dependency, or relevant security weakness from the self-assessment.
- [Organisation Name] understands that PCI DSS compliance is not a one-time activity and must be maintained through ongoing security operations, change control, monitoring, vulnerability management, access management, incident response readiness, and supplier oversight.
- [Organisation Name] will notify relevant stakeholders where significant changes occur that may affect SAQ eligibility, assessment scope, or PCI DSS compliance status.

Assessment Outcome

Assessment Item	Status
SAQ completed	[Yes/No]
All applicable responses supported by evidence	[Yes/No]
All not applicable responses justified	[Yes/No]

Assessment Item	Status
Remediation plan required	[Yes/No]
Compensating controls used	[Yes/No]
Significant scope changes identified during assessment	[Yes/No]
Third-party service provider evidence reviewed	[Yes/No]
Management review completed	[Yes/No]
Attestation approved for submission	[Yes/No]

Exceptions and Remediation

If any exceptions, gaps, or open remediation items exist, they are recorded below and tracked to closure.

Ref	Requirement Area	Description of Gap or Exception	Risk Rating	Owner	Target Completion Date	Current Status
[EX-001]	[Access control / vulnerability management / logging / segmentation / other]	[Description]	[High/Medium/Low]	[Owner]	[Date]	[Open/In Progress/Closed]
[EX-002]	[Area]	[Description]	[High/Medium/Low]	[Owner]	[Date]	[Open/In Progress/Closed]

Where no exceptions are recorded, [Organisation Name] attests that no known unresolved compliance gaps were identified during the self-assessment as of the assessment completion date.

Compensating Controls

Where a security objective could not be met using the standard method expected by PCI DSS, any compensating control has been formally documented, risk-assessed, approved by authorised management, and supported by evidence.

Ref	Control Objective Affected	Reason Standard Approach Is Not Used	Compensating Control Summary	Approval Status
[CC-001]	[Security objective]	[Business or technical constraint]	[Alternative control approach]	[Approved / Not Approved / Not Applicable]

If no compensating controls are used, this section is recorded as not applicable.

Signatory & Authority

This Attestation must be approved by individuals with sufficient authority to represent the accuracy of the self-assessment and the organisation's commitment to maintain PCI DSS compliance.

Required Signatories

Role	Responsibility	Required
Executive Sponsor	Provides management accountability for PCI DSS compliance and accepts organisational responsibility for this Attestation	Yes
PCI Compliance Owner	Confirms the SAQ was completed, evidence was reviewed, and remediation items are tracked	Yes
Information Security Lead	Confirms the security control information provided is accurate and supported by evidence	Yes
Technology Owner	Confirms in-scope systems, architecture, configurations, and technical dependencies are accurately represented	Yes

Role	Responsibility	Required
Business Process Owner	Confirms payment processes, operational practices, and third-party dependencies are accurately represented	Yes
Third-Party or Supplier Manager	Confirms relevant service provider evidence and contractual responsibilities were reviewed	Where applicable

Approval Signatures

Name	Title / Role	Signature	Date
[Executive Sponsor Name]	[Executive Sponsor Title]	[Signature]	[Date]
[PCI Compliance Owner Name]	[PCI Compliance Owner Title]	[Signature]	[Date]
[Information Security Lead Name]	[Information Security Lead Title]	[Signature]	[Date]
[Technology Owner Name]	[Technology Owner Title]	[Signature]	[Date]
[Business Process Owner Name]	[Business Process Owner Title]	[Signature]	[Date]

Authority to Submit

The following individual is authorised to submit the completed SAQ, this Attestation, and any related compliance materials to acquiring banks, payment brands, customers, auditors, assessors, or other authorised recipients.

Authorised Submitter	Role	Contact Details	Submission Authority
[Name]	[Role]	[Email / Phone]	Authorised to submit PCI DSS self-assessment materials on behalf of [Organisation Name]

No other individual may submit or represent PCI DSS self-assessment status externally unless authorised by the Executive Sponsor or PCI Compliance Owner.

Evidence Referenced

The following evidence was referenced in support of the completed Self-Assessment Questionnaire. Evidence must be current, relevant to the assessed environment, and sufficient to support the responses provided.

Core Assessment Evidence

Evidence Item	Description	Evidence Owner	Location / Repository	Review Date
Completed SAQ	Final completed questionnaire for applicable SAQ type	[PCI Compliance Owner]	[Repository / Path]	[Date]
Cardholder Data Flow Diagram	Diagram showing how cardholder data enters, moves through, and exits the environment	[Technology Owner]	[Repository / Path]	[Date]
Network Diagram	Diagram of in-scope networks, security boundaries, connectivity, and segmentation	[Infrastructure Owner]	[Repository / Path]	[Date]
System Inventory	Inventory of in-scope applications, servers, endpoints, payment devices, and supporting systems	[Asset Owner]	[Repository / Path]	[Date]
Payment Channel Inventory	List of payment acceptance methods and business processes	[Business Owner]	[Repository / Path]	[Date]
Third-Party Service Provider List	List of providers with PCI DSS relevance and service descriptions	[Supplier Manager]	[Repository / Path]	[Date]

Evidence Item	Description	Evidence Owner	Location / Repository	Review Date
Responsibility Matrix	Allocation of PCI DSS responsibilities between [Organisation Name] and service providers	[PCI Compliance Owner]	[Repository / Path]	[Date]

Security Control Evidence

Evidence Item	Description	Evidence Owner	Location / Repository	Review Date
Security Policies and Standards	Approved policies governing information security and payment data protection	[Policy Owner]	[Repository / Path]	[Date]
Access Reviews	Evidence of user access review for in-scope systems	[System Owners]	[Repository / Path]	[Date]
Privileged Access Records	Evidence of privileged account management, approvals, and reviews	[IAM Owner]	[Repository / Path]	[Date]
Authentication Configuration	Evidence of authentication settings for administrative and user access	[IAM Owner]	[Repository / Path]	[Date]
Vulnerability Scan Results	Internal and external vulnerability scan results and remediation tracking	[Security Operations Owner]	[Repository / Path]	[Date]
Penetration Test Report	Penetration testing results and remediation evidence, where applicable	[Security Testing Owner]	[Repository / Path]	[Date]
Secure Configuration Evidence	Build standards, configuration baselines, and sample configuration outputs	[Infrastructure Owner]	[Repository / Path]	[Date]
Change Records	Approved changes affecting the in-scope environment	[Change Manager]	[Repository / Path]	[Date]
Logging and Monitoring Evidence	Log collection, alerting, review, and incident triage evidence	[Security Operations Owner]	[Repository / Path]	[Date]
Anti-Malware or Endpoint Protection Evidence	Protection status and monitoring evidence for applicable systems	[Endpoint Owner]	[Repository / Path]	[Date]
Encryption and Key Management Evidence	Evidence showing protection of stored or transmitted cardholder data, where applicable	[Cryptography Owner]	[Repository / Path]	[Date]
Security Awareness Records	Training completion records for personnel with PCI DSS responsibilities	[HR / Training Owner]	[Repository / Path]	[Date]
Incident Response Evidence	Incident response plan, contact list, test records, and lessons learned	[Incident Response Owner]	[Repository / Path]	[Date]

Service Provider Evidence

Evidence Item	Description	Provider	Review Date	Accepted By
Provider Attestation of Compliance	Current provider compliance attestation relevant to services used	[Provider Name]	[Date]	[Reviewer]
Provider Responsibility Documentation	Description of security responsibilities retained by provider and by [Organisation Name]	[Provider Name]	[Date]	[Reviewer]
Contract or Security Addendum	Agreement covering security obligations, notification, and compliance responsibilities	[Provider Name]	[Date]	[Reviewer]
Provider Scope Confirmation	Evidence confirming which services, regions, products, or account configurations are covered	[Provider Name]	[Date]	[Reviewer]

Evidence Quality Criteria

Evidence used to support the SAQ must meet the following expectations:

- It is dated and relates to the assessment period or current control operation.
- It is attributable to a system, process, owner, or provider in scope.
- It is complete enough to support the relevant SAQ response.
- It has not been altered in a way that compromises reliability.
- Screenshots include dates, system names, and relevant configuration details where practical.
- Reports clearly show scan scope, test scope, dates, results, and remediation status.
- Third-party evidence is current and applies to the actual services used by [Organisation Name].
- Sensitive evidence is stored securely and shared only with authorised parties.

Frequency

The Self-Assessment Questionnaire and this Attestation must be completed at least annually and whenever a significant change occurs that could affect PCI DSS scope, SAQ eligibility, control operation, or compliance status.

Standard Cycle

Activity	Frequency	Owner	Output
Confirm SAQ eligibility	Annually and after significant change	[PCI Compliance Owner]	Documented SAQ type rationale
Review cardholder data flows	Annually and after payment process changes	[Business Owner / Technology Owner]	Updated data-flow diagrams
Validate assessment scope	Annually and after architecture, supplier, or process changes	[PCI Compliance Owner]	Approved scope statement
Collect and review evidence	Annually	[Control Owners]	Evidence repository and review record
Complete SAQ	Annually	[PCI Compliance Owner]	Completed questionnaire
Review exceptions and remediation	Monthly until closure	[Remediation Owners]	Updated remediation tracker
Approve Attestation	Annually	Required signatories	Signed Attestation
Submit compliance materials	As requested by acquiring bank, payment brand, customer, or authorised party	[Authorised Submitter]	Submission record

Significant Change Triggers

A new self-assessment review, scope review, or attestation update must be considered when any of the following occur:

- Introduction of a new payment channel, payment page, virtual terminal, POS solution, payment application, gateway, or processor.
- Change from hosted or outsourced payment processing to direct handling of cardholder data, or any other change affecting SAQ eligibility.
- Modification to e-commerce payment flows, scripts, redirects, integrations, or customer payment experience.

- Deployment of new systems, cloud services, network segments, administrative access methods, or security technologies affecting the assessed environment.
- Change to segmentation controls, firewall rules, remote access paths, identity providers, logging coverage, encryption methods, or vulnerability management processes.
- Outsourcing, insourcing, replacement, or material change of a service provider that stores, processes, transmits, or could affect cardholder data security.
- Discovery of previously unknown cardholder data storage, transmission, logging, backup, or reporting.
- Security incident, suspected compromise, major vulnerability, or control failure affecting the in-scope environment.
- Merger, acquisition, divestiture, restructuring, or major business process change affecting payment operations.

Records & Retention

[Organisation Name] must retain this Attestation and all supporting records in a secure, access-controlled repository.

Records to Retain

Record	Minimum Retention Period	Owner	Storage Location
Signed Attestation	[Retention Period, e.g., 3 years]	[PCI Compliance Owner]	[Repository / Path]
Completed SAQ	[Retention Period, e.g., 3 years]	[PCI Compliance Owner]	[Repository / Path]
Evidence referenced in the SAQ	[Retention Period, e.g., 3 years]	[Control Owners]	[Repository / Path]
Scope and SAQ eligibility rationale	[Retention Period, e.g., 3 years]	[PCI Compliance Owner]	[Repository / Path]
Cardholder data flow diagrams	[Retention Period, e.g., 3 years]	[Technology Owner]	[Repository / Path]
Network diagrams and segmentation evidence	[Retention Period, e.g., 3 years]	[Infrastructure Owner]	[Repository / Path]
Third-party provider attestations and responsibility documentation	[Retention Period, e.g., 3 years]	[Supplier Manager]	[Repository / Path]
Remediation plans and closure evidence	[Retention Period, e.g., 3 years after closure]	[Remediation Owners]	[Repository / Path]
Submission confirmations and correspondence	[Retention Period, e.g., 3 years]	[Authorised Submitter]	[Repository / Path]
Management review and approval records	[Retention Period, e.g., 3 years]	[PCI Compliance Owner]	[Repository / Path]

Record Protection Requirements

Records must be protected according to their sensitivity and business value. At a minimum:

- Access must be limited to personnel with a legitimate compliance, security, audit, legal, or management need.
- Evidence containing cardholder data must be avoided wherever possible; where unavoidable, it must be masked, encrypted, and handled through approved secure storage.
- Evidence repositories must be backed up and monitored for unauthorised access or alteration.
- Drafts, working papers, screenshots, exports, and assessment notes must be stored in approved locations and deleted when no longer required.
- External sharing must be approved by the PCI Compliance Owner or authorised delegate.
- Submitted materials must be tracked, including recipient, date, method of transfer, and content shared.

- Superseded versions must be retained or disposed of according to the approved retention schedule.
- Records must be made available to authorised auditors, assessors, acquiring banks, payment brands, legal counsel, or regulators when required and approved by management.

Submission Record

Submission Date	Recipient	Materials Submitted	Submitted By	Transfer Method	Confirmation Received
[Date]	[Acquiring Bank / Payment Brand / Customer / Assessor]	[SAQ, Attestation, remediation summary, supporting evidence]	[Name]	[Secure portal / encrypted email / GRC platform]	[Yes/No - reference]